

FIPS 199 security categorization and information-type inventory

Provisional categorization of the Claude apps gateway deployment, following FIPS PUB 199 (impact levels) and the SP 800-60 method (identify information types → assign C-I-A impact per type → take the high-water mark).

Read this first. This repository is a **client-configurable template**, not a fielded system. The categorization below is *provisional*: it is derived from what the system technically processes, not from a determination about the sensitivity of any organization's data. Two decisions belong to the deploying organization and are marked with placeholders throughout:

1. **What developers are permitted to put in prompts** — this single decision drives the confidentiality impact of the largest information type and can move the whole categorization.
2. **The DoD Cloud Computing SRG impact level (IL)**, if the deployment is a DoD system — see §6.

Every external-service claim in §5 and §7 was verified against current AWS documentation on **2026-07-28** and is cited. Claims that could not be verified are labelled **NEEDS VERIFICATION** rather than stated plausibly.

Contents:

1. [Method and boundary](#)
2. [Information types processed](#)
3. [Impact ratings with rationale](#)
4. [Provisional system categorization](#)
5. [Service-provider data handling \(verified\)](#)
6. [The DoD impact level \(IL4/IL5\) question](#)
7. [Cryptographic module \(FIPS 140\) status](#)
8. [What the deploying organization must decide](#)

1. Method and boundary

The categorization covers the authorization boundary described in `conops.md` §1.4 and `architecture.md` §1: the managed client fleet, the GovCloud workload VPC and all deployed stacks (01–04, plus the optional 05 log-analytics stack, which introduces no new information type — its query results are ALB access-log excerpts), with Okta as the one external SaaS dependency and Bedrock reached over a private endpoint.

Information types below are described **functionally**. They are deliberately **not** mapped to SP 800-60 Volume II type identifiers (c.x.x.x): that mapping depends on the deploying organization's mission and business lines, which this template cannot know. The org's ISSO should map each row in §2 to the applicable SP 800-60 type(s) and revisit the provisional ratings against the recommended provisional impacts for those types.

Credential and key material (secrets, the CMK, TLS private keys) is *not* categorized as an information type here, following the common convention that authenticators are treated as a control surface rather than mission information. Its protection is covered in `control-implementation.md` §8 (IA-5) and §9 (SC-12/SC-28), and the secrets inventory is `architecture.md` §6.

2. Information types processed

ID	Information type	What it is	Where it lives	Volume/exposure
IT-1	Developer prompt content	Source code, file excerpts, error output, design questions and any context the developer's working directory supplies, sent to Bedrock for inference	In transit only by default (client → ALB → gateway → Bedrock). Persisted only if Bedrock prompt logging is enabled (IT-7)	Every session, continuously
IT-2	Model response content	Generated code, explanations, recommended commands returned to the client	In transit only by default; same persistence exception as IT-1	Every session
IT-3	Identity and authentication data	Okta OIDC claims (<code>sub</code> , email, groups), the gateway session JWT, portal session and gateway-bearer cookies, the portal-maintained <code>sub→email</code> map	Gateway PostgreSQL (user identity records, 90 d per gateway config); portal artifacts bucket <code>identity/principal-emails/</code> prefix (CMK); cookies on the client	Every login; one map object per admin principal
IT-4	Usage and cost telemetry	Tokens, cost, model, session id, lines of code, and the stamped user identity plus team/cost-center attribution	AMP workspace (150 d, AMP service default); the authoritative spend ledger is the gateway PostgreSQL <code>spend</code> table (13 months per gateway config)	Continuous while sessions are active
IT-5	AI activity records (opt-in)	Per-user bash commands, tool inputs and file paths. Prompt and response content is redacted from this stream by default; the separate opt-ins <code>LOG_USER_PROMPTS=true</code> and <code>LOG_ASSISTANT_RESPONSES=true</code> (independent of each other) add the full user-typed prompt text and the model's response text respectively (per-user attributed, this gateway's clients only)	CloudWatch <code>/claude/</code> <code><prefix>/activity</code> (14 d window) → Firehose → S3 archive (731 d), both CMK	Only when <code>FORWARD_ACTIVITY_LOGS=true</code> ; bursty, tied to real tool use
IT-6	Administrative and system audit records	Spend-cap changes (<code>admin_audit</code> , actor <code>oidc:<sub></code>), portal downloads/denials/admin events, pgaudit DDL/role/write statements, ALB access logs	Gateway PostgreSQL (365 d); CloudWatch <code>/claude/</code> <code><prefix>/portal-audit</code> (365 d); RDS→CloudWatch pgaudit group (731 d); S3 ALB logs (90 d, SSE-S3)	Continuous
IT-7	Bedrock model-invocation logs (opt-in, off by default)	Verbatim prompts and responses for every <code>bedrock-runtime</code> call in the account and region — not only this gateway's	CloudWatch <code>/claude/</code> <code><prefix>/bedrock-prompts</code> (14 d) and an S3 bucket (731 d). Bodies over 100 KB — typical Claude Code contexts — appear only in S3	Only when <code>BEDROCK_PROMPT_LOGGING=true</code>
IT-8	System configuration and		CloudWatch operational log groups (365 d / 90 d);	Continuous

ID	Information type	What it is	Where it lives	Volume/exposure
	operational telemetry	Container stdout/stderr, collector self-metrics, alarm state, deployment parameters	CloudWatch Metrics (AWS-managed 15 months)	

Retention values and their parameter names are maintained in one place — `../operations/monitoring-and-retention.md §3–§5` — and are cited, not copied, so this document does not drift from it.

3. Impact ratings with rationale

Ratings are **provisional** in the FIPS 199 sense: the recommended starting point, subject to the organization's adjustment. The "escalates to High when" column is the part an AO should read most carefully — it names the specific organizational condition that would raise the rating.

ID	C	I	A	Escalates to High when
IT-1 Prompt content	Moderate	Moderate	Low	The organization permits CUI, export-controlled/ITAR, or otherwise sensitive source code in prompts — the single most consequential org decision in this document
IT-2 Response content	Moderate	Moderate	Low	Model output is relied upon in a safety- or mission-critical path without human review (see §8, output-reliability statement)
IT-3 Identity data	Moderate	Moderate	Low	Group membership drives access to a High-impact system elsewhere, making the identity map itself high-value
IT-4 Usage/cost telemetry	Low	Moderate	Low	— (integrity is Moderate because the PostgreSQL <code>spend</code> table is the <i>enforcement</i> ledger: corrupting it either permits uncapped spend or halts the fleet)
IT-5 Activity records	Moderate	Moderate	Low	The organization treats internal system detail (file paths, host names, command lines) as sensitive, or accepts that operators may type credentials into shell commands — both plausible; the repo already handles this stream as its most sensitive routine data
IT-6 Audit records	Moderate	Moderate	Low	Audit records are the sole evidence source for a regulated process; note the integrity rating is <i>already</i> qualified by the deferred Object Lock decision below
IT-7 Bedrock prompt logs	High	Moderate	Low	— rated High as filed: it is a verbatim, aggregated, account-wide capture of IT-1 and IT-2 with no per-user attribution, and it is the only store holding the >100 KB bodies
IT-8 Operational telemetry	Low	Low	Low	—

Rationale notes worth stating explicitly:

- **Availability is Low across the board, deliberately.** This is a developer productivity tool: an outage stops developers using Claude Code, not a mission function. Two design decisions nonetheless make availability a *chosen* trade rather than an accident — spend enforcement fails closed (a spend-store outage halts inference fleet-wide) and telemetry fails closed by default (a persistently unhealthy collector stops the gateway task). Both are recorded as

accepted risks and both are reversible by parameter. An organization that treats the gateway as mission-essential should raise A to Moderate **and** re-examine those two trades. See `../operations/cost-controls.md §5` and `conops.md §6.2`.

- **IT-7 is High and opt-in for the same reason.** Its blast radius is account+region-wide, it has no per-user attribution (the caller is the gateway task role), and it is off by default. An organization enabling it in a shared account is making a categorization-relevant change, not an operational one.
- **IT-5's redaction matters to the rating.** Prompt and response content is redacted from the activity stream by default, which is why IT-5 sits at Moderate while IT-7 sits at High despite both concerning user content. Enabling `LOG_USER_PROMPTS=true` and/or `LOG_ASSISTANT_RESPONSES=true` removes that redaction: IT-5 then carries verbatim user-typed prompt text and/or model response text with per-user attribution, and by this document's own logic its confidentiality impact rises to that of IT-7 (see the configuration table below). Like IT-7, either is a categorization-relevant change, not an operational one.
- **Integrity of IT-6 is qualified.** S3 Object Lock is deferred by decision: the archives are CMK-encrypted, IAM-scoped, versioned where applicable and `Retain`-protected, but a sufficiently privileged principal can still delete objects or shorten retention. An organization whose audit-integrity requirement is absolute should treat this as an unmet control rather than a Moderate rating (accepted risk A1 in `security-assessment-2026-07.md`).

4. Provisional system categorization

Taking the high-water mark across the information types the system processes **in its default configuration** (IT-7 disabled, IT-5 opt-in):

SC (*Claude apps gateway*) = {(confidentiality, MODERATE), (integrity, MODERATE), (availability, LOW)}

Provisional overall categorization: MODERATE.

With the opt-in surfaces enabled the high-water mark moves:

Configuration	C	I	A	Overall
Default (IT-5 off, IT-7 off)	Moderate	Moderate	Low	Moderate
Activity stream enabled (<code>FORWARD_ACTIVITY_LOGS=true</code>)	Moderate	Moderate	Low	Moderate
Activity stream with prompt and/or response capture (<code>LOG_USER_PROMPTS=true</code> / <code>LOG_ASSISTANT_RESPONSES=true</code>)	High	Moderate	Low	High
Bedrock prompt logging enabled (<code>BEDROCK_PROMPT_LOGGING=true</code>)	High	Moderate	Low	High
Org permits CUI/ITAR/export-controlled content in prompts	High	Moderate	Low–Moderate	High

Placeholder — organizational determination. The final categorization is recorded by the deploying organization's ISSO/AO:

System name:	<deployment name>
Categorization date:	<date>
Confidentiality:	<LOW MODERATE HIGH>
Integrity:	<LOW MODERATE HIGH>
Availability:	<LOW MODERATE HIGH>

Overall (high-water mark):	<LOW MODERATE HIGH>
CUI in prompts permitted:	<yes no categories: _____>
Determined by:	<ISS0> Approved by: <A0>

5. Service-provider data handling (verified)

The most common question an AO asks about a genAI system is what the provider does with the prompts. The following was verified against AWS documentation on **2026-07-28**. Nothing here is asserted from memory.

Verified — Bedrock's default posture. The Amazon Bedrock abuse-detection documentation states that Bedrock uses a **zero operator access (ZOA)** model ("no operators of the service can access model input or output") and a **zero data retention (ZDR)** model ("by default, Amazon Bedrock does not store model inputs or outputs"). ([abuse detection](#))

Verified — the exceptions are per-model and enumerated. The same page lists the models for which AWS "may be required to store inputs and outputs" for abuse detection: specified OpenAI GPT-5.x models (classifier-flagged traffic retained up to 30 days) and Anthropic Claude Fable 5 (inputs and outputs retained up to 30 days, with opt-in sharing to Anthropic required to use the model). **The three models this deployment configures — Opus 4.8, Sonnet 5, Sonnet 4.5 — do not appear on that list as of the verification date.**

Verified — retained data is not shared with model providers absent opt-in. "Retained inputs and outputs are stored and processed by AWS and are not shared with third-party model providers, unless you opt in to sharing with the model provider." AWS also states that model providers have no access to the model deployment accounts and therefore "don't have access to Amazon Bedrock logs or to customer prompts and completions." ([data protection](#))

Verified — retention is an account/project setting with four modes. Bedrock exposes `data_retention_mode` at project and account scope with modes `default`, `provider_data_share`, `none` (zero retention) and `inherit`; the effective mode is the first non-`inherit` value of project → account → model default. Write actions publish a condition key (`bedrock:DataRetentionMode` / `bedrock-mantle:DataRetentionMode`) so an organization can pin the mode by SCP. ([data retention](#))

Verified — cross-region inference changes where retained data lands. "If cross-region inference is enabled for these models, retained inputs and outputs are stored in destination regions (i.e., the region where your inference request is processed)." This is directly relevant here: GovCloud geo inference profiles fan out across us-gov regions, which is why the IAM policies use a region wildcard on the derived foundation-model ARNs (accepted risk A13).

NEEDS ORG CONFIRMATION — the apparent tension in the docs. The data-retention page's "Mixed-model projects" example describes Claude Opus 4.8 as having `allowed_modes: ["default", "provider_data_share"]` and says that for such a model "data is retained by AWS only. The model accepts `provider_data_share` as a valid mode but does not require data to leave AWS's boundary." Read together with the ZDR-by-default statement above, the effective retention for Opus 4.8 under `default` mode is **not unambiguous in the documentation**. Before asserting zero retention in an SSP, the organization should query the effective mode for each configured model through the Bedrock API and record the response as evidence. Do not restate "prompts are never stored" as settled fact on the strength of this document.

Not applicable — Anthropic-hosted infrastructure. The client fleet never contacts Anthropic at runtime: binaries are mirrored and integrity-verified, auto-update paths are disabled, and inference is served from Bedrock inside the GovCloud boundary (`conops.md` §1.3). The only external SaaS dependency in the runtime path is the organization's own Okta tenant.

6. The DoD impact level (IL4/IL5) question

This repository **cannot resolve** the deployment's DoD impact level. What can be stated:

Verified — the region's authorizations. AWS states that AWS GovCloud (US) gives customers the flexibility to architect solutions complying with "the FedRAMP High baseline; the DOJ's Criminal Justice Information Systems (CJIS) Security Policy; U.S. International Traffic in Arms Regulations (ITAR); Export Administration Regulations (EAR); Department of Defense (DoD) Cloud Computing Security Requirements Guide (SRG) for **Impact Levels 2, 4 and 5**; FIPS 140-3; IRS-1075; and other compliance regimes." ([GovCloud compliance](#)) **IL6 is not listed** — a deployment handling classified information is out of scope for this architecture.

Verified — Bedrock model authorizations in GovCloud are announced per model. AWS announced FedRAMP High and DoD CC SRG IL-4/IL-5 approval for Bedrock models in AWS GovCloud (US) in May 2025, naming Anthropic's Claude 3.5 Sonnet v1 and Claude 3 Haiku and Meta's Llama 3 8B/70B, along with Bedrock features (Agents, Guardrails, Knowledge Bases, Model Evaluation); a June 2026 announcement extended the same approvals to OpenAI GPT, GPT OSS and NVIDIA Nemotron models. ([May 2025](#), [June 2026](#))

NEEDS ORG CONFIRMATION — whether *these three models* are in the authorized scope. The three models this deployment serves — Opus 4.8, Sonnet 5 and Sonnet 4.5 — are **not** named in the announcements found. Model-level authorization scope changes over time and is not something this repository can assert. Before submission, confirm with the AWS account team and the FedRAMP Marketplace / AWS services-in-scope listing that each configured model ID is within the authorization boundary the deployment intends to rely on, and record the answer here. If a configured model is *outside* the required scope, the remedy is a parameter change (`OPUS_MODEL_ID` / `SONNET_MODEL_ID` / `HAIKU_MODEL_ID` and their Bedrock profile IDs), not an architecture change.

What the IL determination depends on — the questions an org must answer, none of which this template can:

Question	Why it matters	Owner
Is any DoD information processed at all?	If not, the SRG does not apply and FIPS 199 + FedRAMP is the whole frame	Org / sponsor
What CUI categories may appear in prompts?	Drives IL4 vs IL5 and the confidentiality rating in §3	Data owner
Is this a National Security System?	IL5 for NSS has additional separation requirements; IL6 is out of scope for GovCloud per the citation above	AO
Is the workload account dedicated or shared?	Bedrock prompt logging (IT-7) is account-wide — enabling it in a shared account captures other tenants' invocations	Landing-zone owner
Which mission systems does the source code in prompts belong to?	Source code frequently inherits the categorization of the system it implements	Data owner

Placeholder:

DoD impact level: <not applicable | IL2 | IL4 | IL5>
 Determination basis: <____>
 Sponsoring DoD component / AO: <____>

7. Cryptographic module (FIPS 140) status

Stated honestly, leg by leg. Two legs are verified, three are not.

Leg	Module / policy	Status
Client → ALB (TLS 1.2/1.3)	Listener defaults to <code>ELBSecurityPolicy-TLS13-1-2-FIPS-2023-04</code> (template parameter <code>TlsSecurityPolicy</code> , <code>cloudformation/02-gateway.yaml</code>). AWS states "All FIPS policies leverage the AWS-LC FIPS validated cryptographic module" and links CMVP certificate 4631	Verified (ALB security policies)
ALB → task (re-encryption)	Not selectable. AWS states that when a listener uses a FIPS policy, backend connections use <code>ELBSecurityPolicy-TLS13-1-0-FIPS-2023-04</code> — a policy AWS flags as "provided for legacy compatibility only... may not conform to the latest NIST guidance for TLS configuration," and which admits TLS 1.0/1.1	Verified, and worth an AO's attention — the backend policy is not operator-controllable
Keys at rest (KMS CMK)	AWS KMS "relies on a distributed fleet of FIPS 140-3 Security Level 3—validated hardware security modules"	Verified (KMS data protection)
Task → AWS APIs (Bedrock, AMP, Secrets Manager, Logs, ECR, S3)	The templates create standard interface/gateway endpoints (<code>com.amazonaws.<region>.<service></code>); no FIPS endpoint is configured anywhere in the repo and no <code>AWS_USE_FIPS_ENDPOINT</code> is set. Verified by inspection: the only occurrence of "FIPS" in <code>cloudformation/</code> or <code>scripts/</code> is the ALB policy parameter	Verified as absent — an org decision. AWS's guidance is to use a FIPS endpoint if FIPS 140-3 validated modules are required for API access
Per-task TLS (gateway/ Grafana/portal listeners) and RDS <code>verify-full</code>	The listener certificate is generated at image build (the runtime image carries no <code>openssl</code> , per <code>docker/entrypoint.sh</code>). Which cryptographic module terminates these TLS sessions inside the container runtimes is not established in-repo	NEEDS VERIFICATION
Client-side (Claude Code binary) TLS	Not established in-repo	NEEDS VERIFICATION

Region-level statement, verified: the AWS GovCloud (US) compliance page lists FIPS 140-3 among the regimes the region supports (citation in §6).

A deeper crypto-module write-up — including how to confirm the negotiated policy on a live listener — is registered as a documentation gap (`ato-package-gaps.md` GAP-14).

8. What the deploying organization must decide

Consolidated so an ISSO can work through it in one pass. None of these is answerable from the repository.

#	Decision	Feeds	Owner
1	Data classes permitted in prompts (and the prohibition list: credentials, PII, classified, export-controlled)	§3 IT-1/IT-2 ratings, §4 categorization, Rules of Behavior (ato-package-gaps.md GAP-7)	Data owner + ISSO
2	Whether the AI activity stream is enabled, and who may read it	§3 IT-5, privacy analysis (GAP-6)	ISSO + privacy office
3	Whether Bedrock prompt logging is enabled, and whether the account is dedicated	§4 (moves the categorization to High), §6	ISSO + landing-zone owner
4	SP 800-60 Volume II type mapping for each row of §2	§3 provisional ratings	ISSO
5	Availability objective — is the gateway mission-essential?	§3 availability rating; the two fail-closed trades; RTO/RPO (GAP-5)	Mission owner
6	DoD impact level, if applicable	§6	AO / sponsor
7	Whether FIPS service endpoints are required for AWS API traffic	§7 row 4; a configuration change, not an architecture change	ISSO
8	Confirmation that each configured Bedrock model ID is within the authorization scope relied upon	§6	ISSO + AWS account team
9	Retention mode to pin for Bedrock (none / default), enforced by SCP if required	§5	ISSO
10	Whether model output may be relied on without human review, and where that is stated to users	§3 IT-2, Rules of Behavior (GAP-7)	Mission owner

Companion documents: control mapping in [control-implementation.md](#) ; open findings in [poam.md](#) ; accepted risks and their rationale in [security-assessment-2026-07.md](#) ; retention and destination facts in [../operations/monitoring-and-retention.md](#) . External-service claims in §5–§7 were verified 2026-07-28; re-verify before any resubmission, since AWS model authorizations and Bedrock retention semantics both change.